Request for Quotation: Google CASA Security Assessment (App Defense Alliance)

Applicant: ArquivIO, operated by VL PEREZ LTDA (CNPJ 61.265.563/0001-04), R Virola 66, Dom Pedro I, Manaus/AM, Brazil, CEP 69040-360
Date: October 13, 2026
Contact: Vitor Perez, Founder/CEO · lagevitor.dev@gmail.com · +55 92 8271-9710
Reply requested by: October 27, 2026

1. Company and application overview

ArquivIO is a B2B SaaS product for document intelligence, operated from Brazil. Organizations connect their cloud document stores (Google Drive, Microsoft OneDrive/SharePoint, Notion, ClickUp), and ArquivIO extracts text from the selected folders, indexes it, and lets members of that organization ask questions and receive answers with citations to the source documents. It also offers a read-only public API and an MCP server for programmatic access.

- **Stage:** early. A small number of pilot customer organizations today; we estimate about 20 organizations and 200 end users over the next 12 months.
- **Team:** 1 engineer (the founder). There is no dedicated security staff, so we value clear, actionable findings and a defined remediation and retest process.
- **Public pages:** https://www.arquivio.com.br (application and marketing site), https://www.arquivio.com.br/privacidade (privacy policy), https://www.arquivio.com.br/termos (terms of service).

2. Purpose of this request

Google classifies `https://www.googleapis.com/auth/drive.readonly` as a **restricted scope**. Because ArquivIO stores data derived from the user's Drive (extracted text, chunks, embeddings, metadata) on servers we operate and serves organizations other than ourselves, we do not qualify for any of the exemptions in Google's restricted scope verification requirements. We therefore need an independent security assessment by a Google-authorized CASA lab, and a **Letter of Assessment (LOA)** to submit to Google's OAuth verification team.

We would like to:

1. Obtain a quote for the initial assessment, plus the annual revalidation that Google requires (every 12 months from the LOA date).
2. Have you **confirm the tier** that applies to us. Based on our architecture (cloud-hosted SaaS, server-side storage of derived Drive data, no on-device component) we expect **CASA Tier 2**, but we want the lab's confirmation, including the criteria that decide it.

Our Google OAuth consent screen, domain verification and demo video are being prepared in parallel. Our Google Cloud project number and OAuth client ID can be shared under NDA.

3. Scope of assessment

3.1 OAuth scopes requested

Scope	Classification	Purpose
`https://www.googleapis.com/auth/drive.readonly`	Restricted	Read and download the files in folders the customer selects, and detect new or changed files

This is the only Google scope we request. We do not request `openid`, `email`, or profile scopes. The connected account's e-mail is read from the Drive `about` endpoint. We request offline access (refresh token) so that background synchronization can run without the user present.

We evaluated `drive.file` with the Google Picker as a non-restricted alternative. A proof of concept showed that selecting a folder grants access only to the folder itself, not to its existing or new children, which breaks recursive folder synchronization. This is the basis of our scope justification to Google.

3.2 Data flows

1. **Consent.** A signed-in member of an organization starts the connection. The server issues a single-use, session-bound `state` value and redirects to Google. The callback is `https://www.arquivio.com.br/api/data-sources/google/oauth/callback`, proxied to the API.
2. **Token storage.** The server exchanges the code for tokens and stores them encrypted at rest in PostgreSQL.
3. **Synchronization.** A Celery worker runs on a schedule (every 15 minutes) and on demand. It lists the files in the selected folders, then uses the Drive Changes API (incremental page tokens, with a full-snapshot fallback) to process only changes. Google Docs, Sheets and Slides are exported (text, XLSX, PPTX). Other supported formats (PDF, DOCX, XLSX, PPTX, text, images with OCR) are downloaded.
4. **Processing and storage.** Text is extracted in memory and temporary storage. The original file is not retained. We store extracted text, chunks, vector embeddings (pgvector), and metadata (file name, folder path, links, timestamps) in PostgreSQL, partitioned logically by organization.
5. **AI processing (subprocessor).** Chunks of document text are sent to the **OpenAI API** to generate embeddings and answers, with `store: false` set on the requests. Retrieved text is treated as untrusted data in prompts (prompt-injection hardening).
6. **Access.** Members of the owning organization, through the web application, the API (hashed API keys) and the MCP server. Answers cite source documents.
7. **Disconnection.** The user disconnects the account. The server makes a best-effort call to Google's token revocation endpoint (`https://oauth2.googleapis.com/revoke`) and clears the stored credentials. Removing a folder from the library deletes the associated documents, chunks, embeddings and queries from the active database.

3.3 Components and hosting

Component	Technology	Notes
Web frontend	Next.js 16 / React 19 (Node)	Public at `www.arquivio.com.br`; proxies `/api` to the API so session cookies stay on the frontend host

Component	Technology	Notes
API	Python 3.12, FastAPI	Public at `api.arquivio.com.br` (versioned `/v1` routes, health endpoints)
Worker and scheduler	Celery, Celery beat, Redis broker	Internal only, no public domain
Database	PostgreSQL with pgvector	Internal only, no public access
Cache and rate limiting	Redis	Internal only
OCR sidecar	Docling Serve (Tesseract)	Internal only; not deployed in production at the time of writing, added to scope if enabled
MCP server	Python, optional service	Not currently deployed to production and has no public domain; not in assessment scope (we would add it as an addendum if deployed later)
Hosting	Railway (container platform), region us-east4 (Virginia, USA)	Services in one project and one region; private networking between services
DNS and TLS	Domain registered at HostGator; TLS terminated by Railway	

Third-party subprocessors: Railway (hosting, database), OpenAI (text processing), WorkOS (authentication), Resend (transactional e-mail).

3.4 Authentication and authorization

- End users: e-mail and password through WorkOS AuthKit, server-side session cookie (`HttpOnly`, `Secure`, `SameSite=Lax`, 7-day TTL). Two-factor authentication (MFA) is enabled through WorkOS.
- Roles per organization (Owner, Admin, Member); Google connection management is restricted to authorized roles.
- Programmatic access: API keys stored only as SHA-256 hashes, with per-key and per-organization rate limits; MCP access with token authentication (its validation is still in progress on our side).
- Multi-tenancy: every query is scoped by `organization_id` derived on the server from the credential.

3.5 Environments available for testing

Environment	URL	Notes
Production	https://www.arquivio.com.br · https://api.arquivio.com.br	Real customer data. We would prefer testing in staging and limiting production to non-intrusive checks.
Staging	To be provisioned before kickoff (production is the only environment today)	Own database, Redis and credentials; no real OAuth tokens or customer data
Test accounts	We will provision test accounts at each role (Owner, Admin, Member), plus a test Google account with a prepared Drive	
Source code	Available under NDA, read access on request	Python and TypeScript monorepo

Environment	URL	Notes
Estimated users	Pilot stage today; about 20 organizations and 200 users expected within 12 months	

4. Security controls already in place

These are verified against our codebase as of October 13, 2026. We list them so you can scope effort accurately; we do not claim they are sufficient for the assessment.

Credentials and secrets - Google access and refresh tokens are encrypted with Fernet (AES-128-CBC with HMAC) before storage. Keys are provided only through environment variables of the hosting platform, with a separate key per provider. Key rotation exists in the keyring design but is not yet an automated procedure (known gap). - Sync cursors are stored encrypted. - Logs are tested to exclude secrets and provider error bodies. Provider errors are never logged on token revocation failure. - API keys are stored as SHA-256 hashes and compared in constant time.

OAuth implementation - Single scope, `drive.readonly`. `state` parameter is single-use, tied to the user session, and stored hashed. The callback handles user cancellation (`access_denied`) and missing parameters without leaking details. - Automatic access-token refresh with row-level locking to prevent concurrent refresh; invalid refresh tokens move the connection to a "reauthorization required" state. - Token revocation at Google when the user disconnects (best effort; deployed to production on October 13, 2026).

Application security - Cookie-authenticated mutations are rejected unless the `Origin` matches the application's canonical origin; CORS allows only that origin. - Session cookies are `HttpOnly`, `Secure` outside development, `SameSite=Lax`. - Redis-backed rate limiting on the public API and MCP server, and on expensive AI endpoints. - Tenant isolation enforced in the data-access layer, with automated tests, including PostgreSQL integration tests. - Prompt-injection controls for retrieved documents (untrusted-content fencing, read-only retrieval tools, link sanitization), documented in an internal threat model. - Audit trail for authenticated API/MCP calls, storing query hashes and lengths rather than content. - Documented outbound HTTP policy with bounded retries, backoff and timeouts.

Infrastructure and operations - Database and Redis have no public exposure; only the frontend and API have public domains. - All secrets live in platform environment variables, not in the repository. - Continuous integration runs linting, unit, API and PostgreSQL integration tests, an API contract check and a single-migration-head check on every change. - Database backups: no scheduled, tested backup is confirmed enabled today. We will enable scheduled Railway volume backups plus an off-platform `pg_dump`, with a documented retention period, before kickoff.

Known gaps we expect you may find (we prefer to state them): no completed SAST/DAST/dependency-audit report yet (we plan to run these before kickoff, see section 5); Fernet key rotation is not automated; there are no HTTP security headers beyond the login page (HSTS, CSP, X-Frame-Options and X-Content-Type-Options are not set at the application layer; we checked both public domains with `curl -I` on October 13, 2026 and the hosting platform adds none of them); no general data retention period or documented backup purge; our privacy policy is being updated to include Google's Limited Use disclosure.

5. What we need from you

Please answer each item, in writing, in your quote.

Scope and tier 1. Do you confirm **CASA Tier 2** for this application? If not, which tier and why? What would change the tier? 2. Based on section 3, is anything missing that you need to scope the work (for example, the MCP server, the OCR sidecar, the mobile or browser components, infrastructure)?

Pricing 3. Price for the initial assessment, by tier if there is any ambiguity. Currency and payment terms (card, wire; invoicing to a Brazilian legal entity; withholding taxes). 4. Price for the **annual revalidation** and whether it differs from the initial assessment. Any multi-year or early-renewal discount. 5. What is included: automated scan, manual review, questionnaire/SAQ review, re-scan or retest after remediation, and **how many remediation rounds** are covered. Price of each additional round. 6. Any additional fees (portal, LOA issuance, Google submission, expedited handling, expiry of quote).

Process and timeline 7. Typical elapsed time from kickoff to **LOA**, and from signed quote to kickoff. Earliest start date you can offer. 8. Is a **self-scan** accepted as evidence (for example OWASP ZAP, Fluent/Fluid Attacks, Semgrep, pip-audit/npm audit)? If so, which tools, which versions and which report formats? Do you run your own scan in addition? 9. What access do you need: staging URL, test accounts, source code, architecture diagram, questionnaire answers? Production testing: required or optional? 10. What are the rules around remediation windows and retest, and how long after remediation do we have to complete the retest?

Deliverables and compliance 11. Delivery format of the report and the LOA (PDF, portal upload, direct submission to Google). Can you submit directly to Google, or do we? 12. Validity of the LOA, and what triggers early re-assessment (architecture or scope changes). 13. Will you sign a mutual **NDA** before we share architecture or source code? Please send your template. 14. Do you offer a remediation advisory call, and is it included?

References 15. Brief references or examples of comparable small-SaaS Drive integrations you have assessed, if you can share them.

6. Desired timeline and response deadline

Milestone	Target
Quote received	October 27, 2026
Lab selected, NDA and contract signed	November 3, 2026
Kickoff and scan	November 10, 2026
Findings remediated and retested	December 1, 2026
LOA issued	December 15, 2026
Submission to Google	December 2026

We are flexible on dates in exchange for clear scope and pricing. We are comparing quotes from 2-3 labs and will decide by October 31, 2026.

7. Attachments available on request (under NDA where noted)

- Architecture and data-flow diagram, with the component list above
- Google data-flow description (what is read, stored, sent to subprocessors, deleted)
- Privacy policy and terms of service (public URLs above)
- Threat model for API, MCP and channels; prompt-injection hardening notes
- Test accounts, staging environment details (NDA)
- Source code access or targeted excerpts (NDA)
- Dependency inventory (`pyproject.toml`, `package.json` and lockfiles)
- Results of our own scans (after we run them)
- Google OAuth consent screen configuration and scope justification

---

Cover e-mail (short)

Subject: RFQ: Google CASA Tier 2 assessment for ArquivIO (drive.readonly), quote requested by October 27, 2026

Hello [Lab contact name],

I am Vitor Perez, Founder/CEO at ArquivIO (operated by VL PEREZ LTDA, CNPJ 61.265.563/0001-04), a B2B document-intelligence SaaS based in Brazil. We need a CASA assessment and Letter of Assessment for Google's restricted scope verification (`drive.readonly`), and we are collecting quotes from a few authorized labs.

The attached RFQ describes our architecture, OAuth scope, data flows and existing security controls, and lists the questions we need answered: tier confirmation, price for the initial assessment and annual revalidation, what is included (retest rounds, self-scan acceptance), typical time to LOA, report format, payment terms and your earliest start date.

Could you reply with a quote by October 27, 2026? We can sign an NDA first if you need one before we share more detail. I'm happy to do a 30-minute call if that is easier.

Thank you,
Vitor Perez
Founder/CEO, ArquivIO
lagevitor.dev@gmail.com · +55 92 8271-9710
https://www.arquivio.com.br